

CET104 – UFCD9192

Trabalho Final Nº1 de Módulo Análise de Vulnerabilidades - Iniciação



Trabalho efetuado por: João Manuel de Carvalho Cordeiro – Nº 36203

Índice

Conteúdo

Trabalho Final Nº1 de Módulo Análise de Vulnerabilidades - Iniciação	1
Introdução	3
Objetivos	3
Enunciado / Exercícios	4
Kali	5
Download do PCAP e Executável EXE	6
Download Wireshark	7
Identificação da máquina infetada	8
Exercício 1: IP, MAC Address e Hostname da máquina infetada	9
Exercício 2: Conta do User da máquina infetada	10
Exercício 3: IP usado na “entrega” da infeção	11
Exercício 4: Hash SHA256 do ficheiro executável EXE	12
Exercício 5: Tipo de Malware que infetou a máquina	14
Exercício 6: IP do host que infetou a máquina	15
Exercício 7: Domínio do host que infetou a máquina	16
Bibliografia	17
Conclusão	18

Introdução

Este trabalho foca-se na análise forense de uma captura de tráfego de rede (ficheiro PCAP) e de um ficheiro executável malicioso, com o objetivo de investigar um incidente de segurança.

Inicialmente, transferei o ficheiro PCAP e o executável para o Kali Linux, garantindo que o ficheiro executável não fosse aberto ou executado em nenhum momento.

Com os ficheiros seguramente no ambiente, procedi à investigação usando o Wireshark para analisar o tráfego de rede e ferramentas de linha de comando para realizar análise estática do ficheiro executável. As evidências permitiram responder às sete questões do enunciado.

Objetivos

Os principais objetivos deste trabalho foram:

- Desenvolver competências em análise forense de tráfego de rede.
- Identificar indicadores de comprometimento em capturas PCAP.
- Praticar análise estática de ficheiros executáveis de forma segura.
- Compreender ataques e técnicas de malware.
- Documentar evidências de forma clara e metodológica.
- Primeiro contacto com investigação de incidentes de segurança.

Acredito que estes objetivos tenham sido atingidos com sucesso, conforme detalharei na conclusão.

Enunciado / Exercícios

Exercício 1:

Qual é o IP, MAC address e hostname da máquina Windows infetada?

Exercício 2:

Qual é a conta do user da máquina Windows infetada?

Exercício 3:

Qual é o ip utilizado na “entrega” desta infeção?

Exercício 4:

Qual é a hash do SHA256 do ficheiro executável (EXE) retirado do sistema infetado?

Exercício 5:

Com base nos alertas, que tipo de malware infetou este sistema Windows?

Exercício 6:

Qual é o ip do host que infetou o Windows?

Exercício 7:

Qual é o domínio do host que infetou o sistema?

Se não quiser ver as configurações/downloads feitos pode ir para a página [8](#).

Kali

Para este trabalho vou usar o kali de um trabalho anterior com poucas configurações. Instalei a OVA dele desta forma:

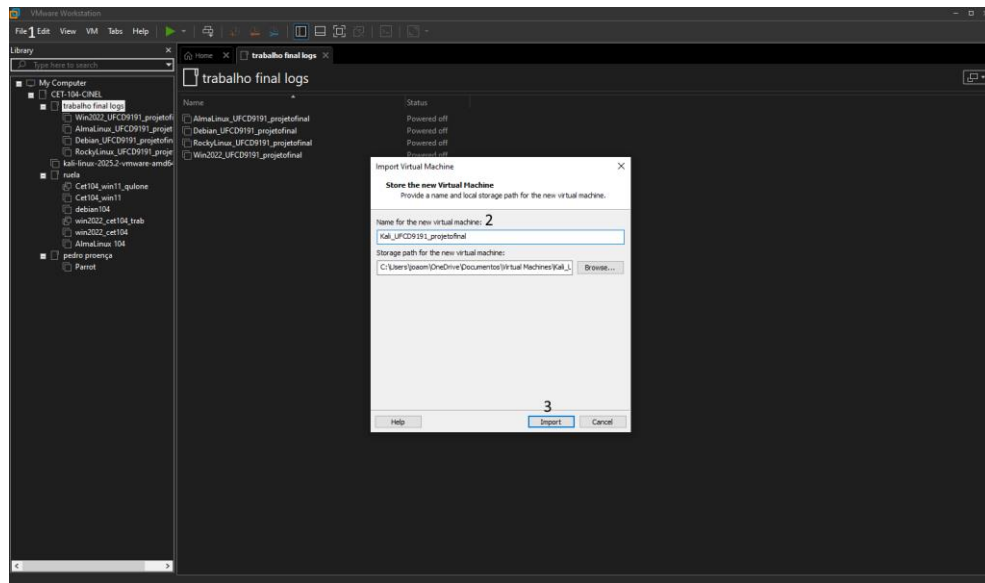


Figura 1 Criação do Kali Ova

1-Seleccione “Open” e abra a OVA do kali. 2- Deje um nome. 3- Clique “Import”.

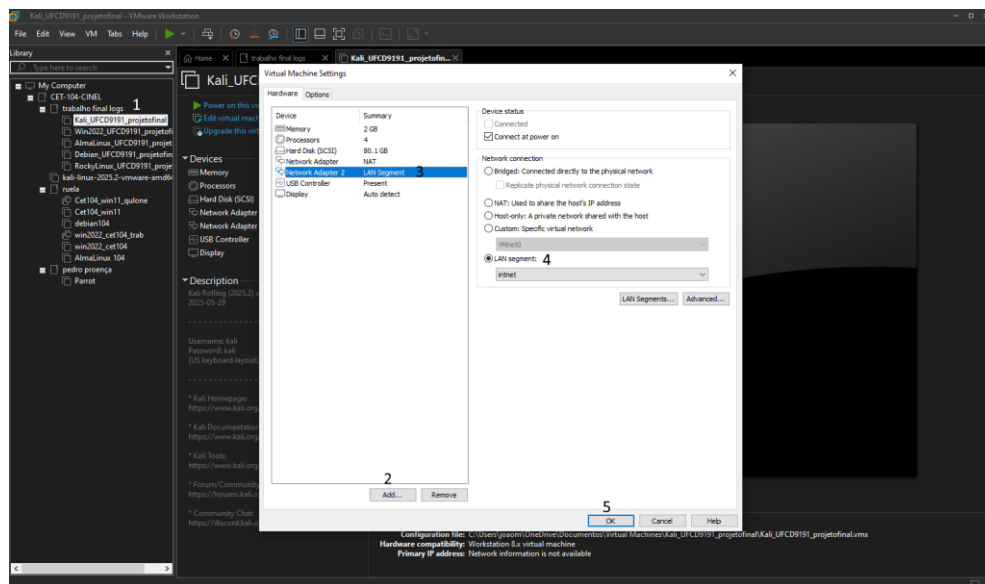


Figura 2 Criação do Kali Ova

1-Seleccione a máquina criada e com o botão direito do rato clique em “Settings”.
2- Clique em “Add” e adicione uma “Network Adapter”. 3-Clique em “Network Adapter 2”.
4-Clique em “LAN Segment” e seleccione o segment “intnet”. 5-Clique em “OK”.

Download do PCAP e Executável EXE

Como indicado vou instalar os ficheiros PCAP e Executável EXE fornecidos pelo formador através do email.

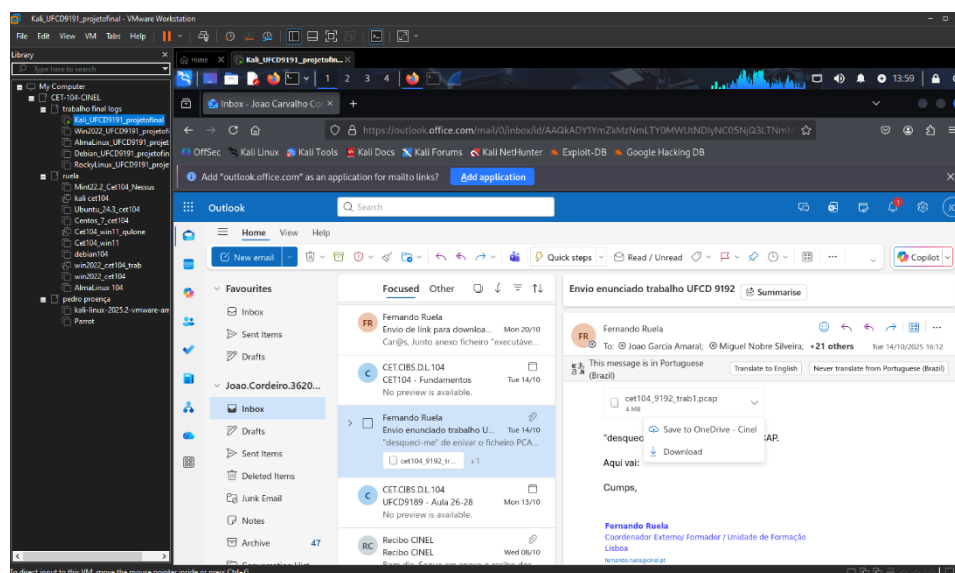


Figura 3 Download do PCAP

Este ficheiro executável é apenas para ser utilizado no exercício 4 para SHA256 e não deve ser aberto/executado.

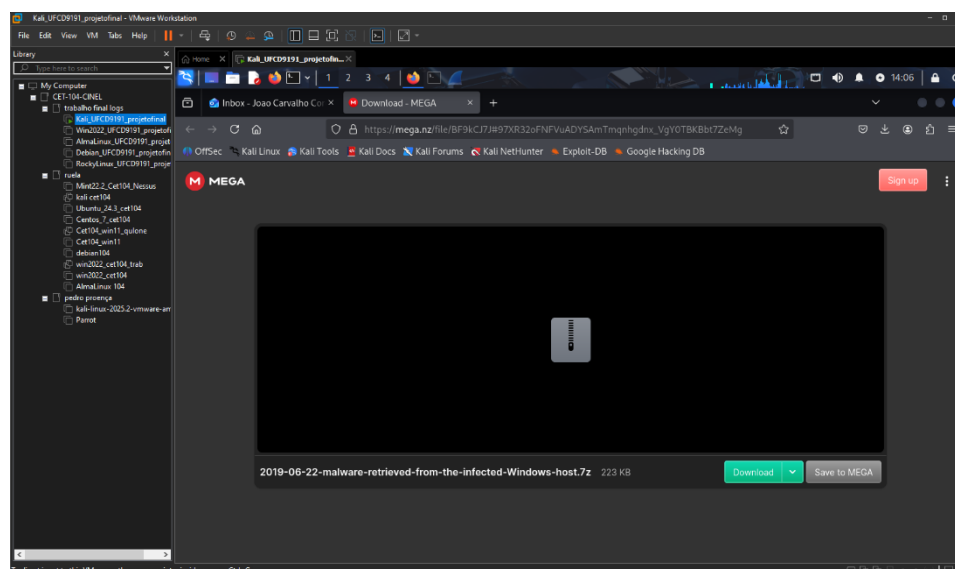


Figura 4 Download do Executável EXE

Identificação da máquina infetada

Primeiro, foi necessário identificar a máquina infetada.

Utilizando a imagem de alertas no tráfego fornecido pelo formador, foram detetados vários erros, incluindo indícios de infeção.

Src IP	SPort	Dst IP	DPort	Pr	Event Message
35.226.156.55	443	10.0.76.193	49207	6	ET POLICY Lets Encrypt Free SSL Cert Observed
10.0.76.109	49204	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Jun 13 2017
37.46.135.170	80	10.0.76.109	49204	6	ETPRO CURRENT_EVENTS RIG EK Landing Apr 04 2017 M5
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Suspicious Possible CollectGarbage in base64 1
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Obfuscated fromCharCode
10.0.76.109	49203	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Mar 13 2017 M2
10.0.76.109	49203	37.46.135.170	80	6	ET POLICY Outdated Flash Version M1
37.46.135.170	80	10.0.76.109	49203	6	ETPRO CURRENT_EVENTS RIG EK Flash Exploit Sep 05 2017 (FWS)
10.0.76.109	49209	8.209.83.76	80	6	ET TROJAN Generic gate[.].php GET with minimal headers
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no referer
10.0.76.109	49211	8.209.83.76	80	6	ETPRO TROJAN KPOT Stealer Exfiltration M2
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no accept headers
74.125.138.1...	80	10.0.76.193	49216	6	GPL WEB_CLIENT web bug 0x0 gif attempt
35.226.156.55	80	10.0.76.193	49261	6	GPL WEB_CLIENT web bug 0x0 gif attempt

Figura 1 Alertas encontrados no tráfego

Figura 7 Alertas encontrados no tráfego fornecidos pelo formador

O endereço IP 10.0.76.109 foi identificado como a máquina infetada, com base na seguinte sequência de eventos maliciosos:

1) O host 10.0.76.109 iniciou comunicação com o IP malicioso 37.46.135.170 (porta 80).

Foram gerados múltiplos alertas associados ao RIG Exploit Kit, incluindo:

- ET CURRENT_EVENTS RIG EK URI Struct
- ETPRO CURRENT_EVENTS RIG EK Landing
- ET POLICY Outdated Flash Version
- ETPRO CURRENT_EVENTS RIG EK Flash Exploit

Estes alertas indicam que o 10.0.76.109 visitou uma landing page maliciosa que explorou uma vulnerabilidade (provavelmente no Adobe Flash) para comprometer o sistema.

2) Imediatamente a seguir, o mesmo host 10.0.76.109 começou a comunicar com outro IP malicioso, 8.209.83.76 (porta 80).

Estabeleceu ligação para um ficheiro gate.php, um endpoint de Command & Control (C2) comum.

O alerta crítico ETPRO TROJAN KPOT Stealer Exfiltration M2 foi acionado, confirmando que o malware específico instalado no sistema foi o KPOT Stealer, um Trojan desenhado para roubo de informação.

Com isto confirmamos que o host 10.0.76.109 está infetado, sendo o host 37.46.135.170 o culpado.

Esta informação será importante para os próximos exercícios.

Exercício 1: IP, MAC Address e Hostname da máquina infetada

Vou procurar as informações do host 10.0.76.109 com o filtro “dhcp”.

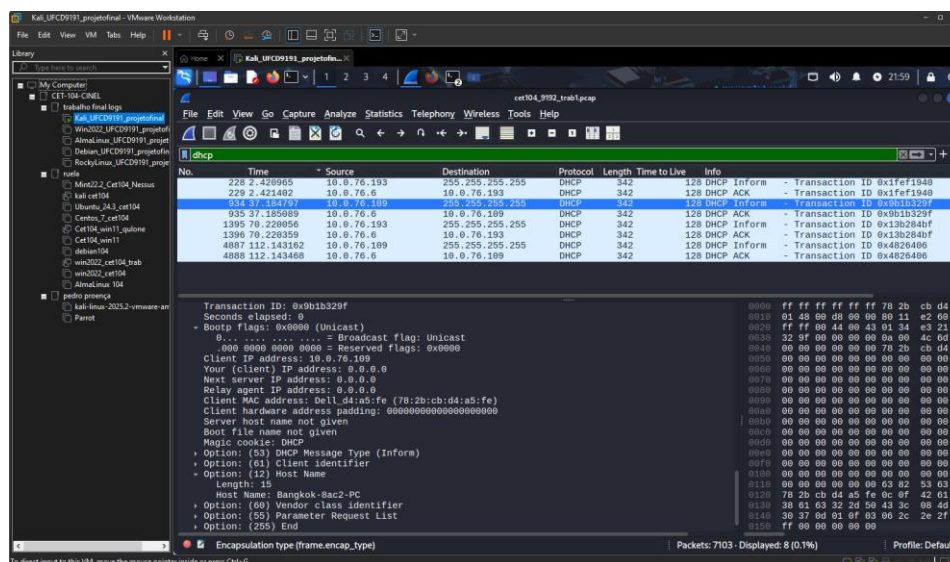


Figura 8 IP, MAC Address e Hostname do 10.0.76.109

Dentro do “Dynamic Host Configuration Protocol” podemos verificar o IP, MAC Address e Hostname da máquina:

Bootp flags: 0x0000 → Client IP Address: 10.0.76.109

Bootp flags: 0x0000 → Client MAC address: 78:2b:cb:d4:a5:fe

Option: (12) Host Name → Host Name: Bangkok-8ac2-PC

Pode-se ver também que ativei uma coluna extra de “Time To Live” que confirma se a máquina é windows ou outra, neste caso 128 é do windows.

Exercício 2: Conta do User da máquina infetada

Usando o filtro “(ntlmssp || kerberos) && ip.addr == 10.0.76.109”, navegando para: Kerberos → as-req → req-body → cname → cname-string: 1 item → CNameString: bangkok-8ac2-pc\$

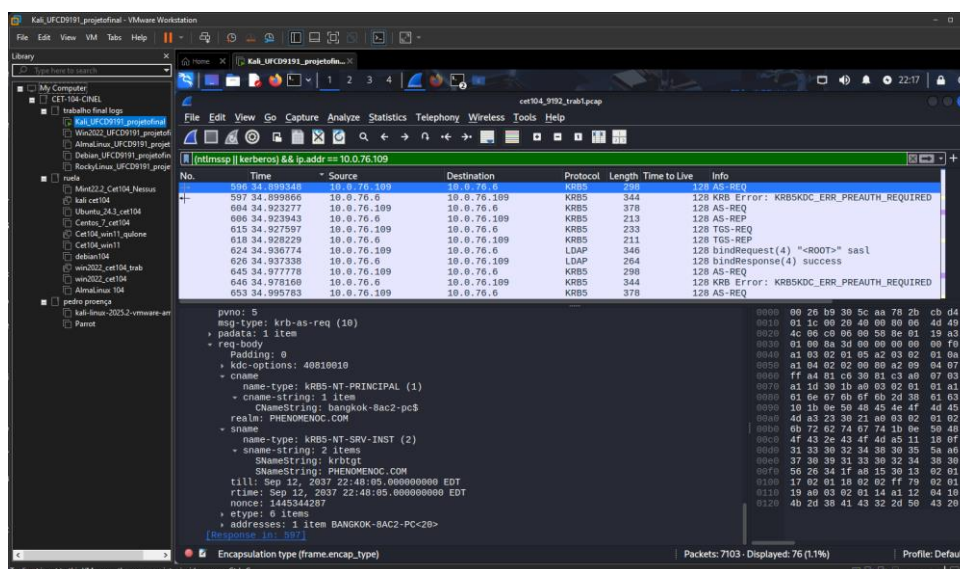


Figura 9 Conta do 10.0.76.109

Assim verificamos a conta user da máquina infetada.

Exercício 3: IP usado na “entrega” da infeção

Como tinha verificado antes na secção “Identificação da máquina infetada”, este ataque teve como alvo o host 10.0.76.109 e o atacante enviou-lhe ficheiros maliciosos diretamente para o infetar.

Resumindo, o ip usado na entrega da infeção foi o 37.46.135.170 pois ele enviou ficheiros maliciosos a uma máquina da rede.

E pode-se dizer que o host 8.209.83.76 é o ponto de entrega final onde se recolhe a informação roubada.

Exercício 4: Hash SHA256 do ficheiro executável EXE

Para este exercício é importante ter bastante cuidado para não executar o ficheiro teste de malware, sendo o objetivo extrair-lo e efetuar o SHA256.

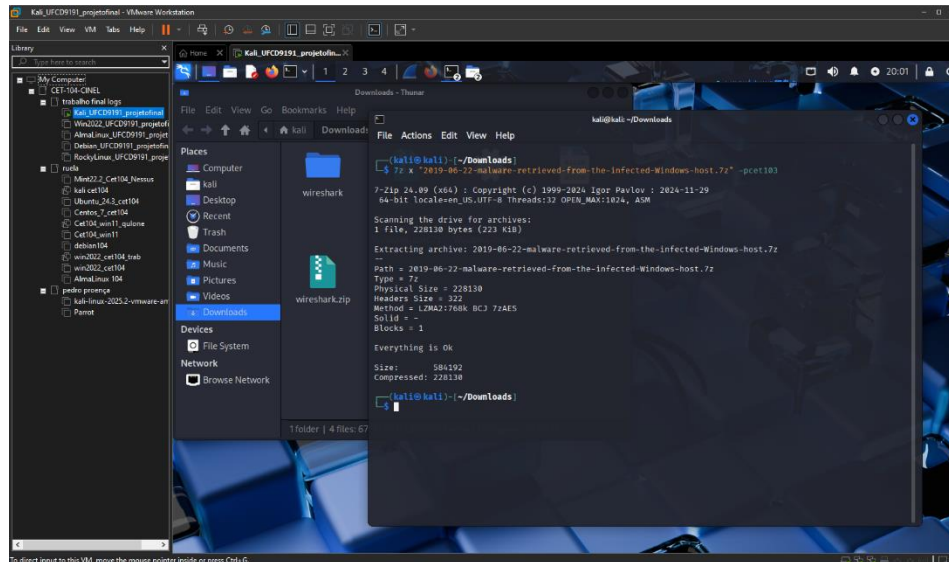


Figura 10 Extração do ficheiro Malware

Depois de extraído vamos efetuar o SHA256

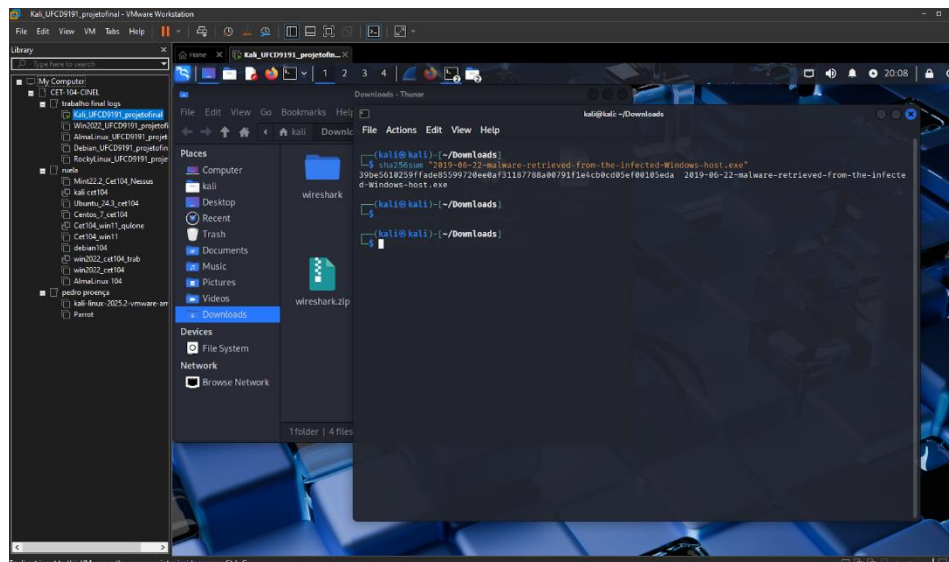


Figura 11 SHA256 do ficheiro .exe do Malware

SHA256 do ficheiro:
39be5610259ffade85599720ee0af31187788a00791f1e4cb0cd05ef00105eda

Pode-se também verificar (usando o sha extraído) o perigo desse ficheiro malware no website: <https://www.virustotal.com/gui/home/search>.

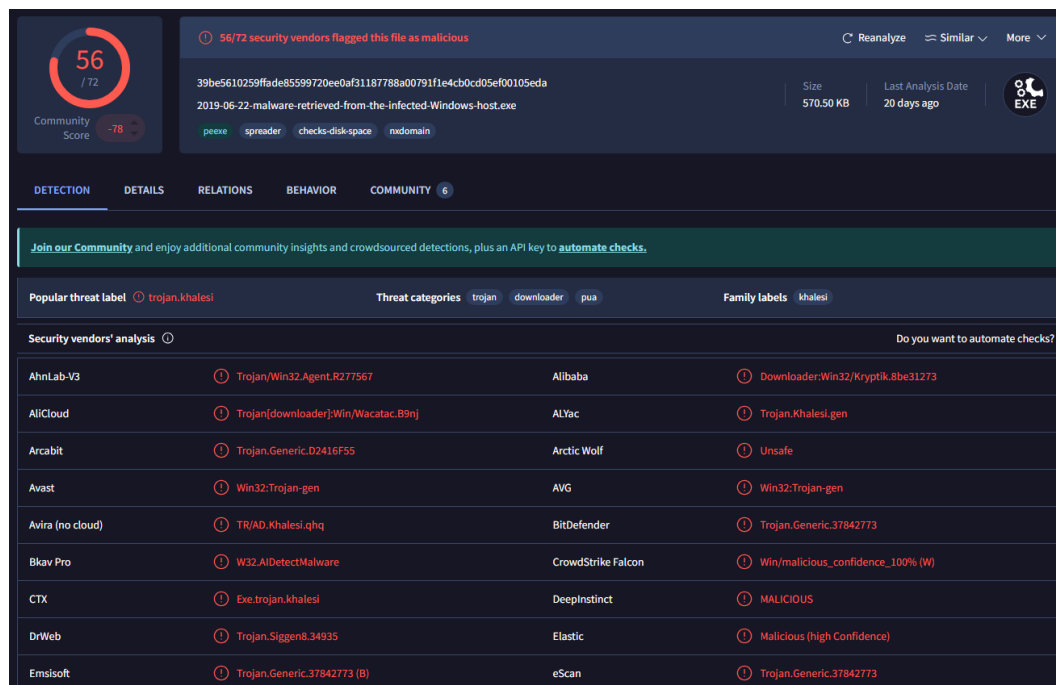


Figura 12 Verificação do nível de perigo deste ficheiro malware usando o site vírus total

Para maior segurança, sendo que o exercício está feito, pode-se remover o ficheiro malware da máquina virtual para evitar vírus acidentais na nossa máquina.

Exercício 5: Tipo de Malware que infetou a máquina

Com base nos alertas de tráfego analisados, o sistema Windows foi infetado por um Trojan de roubo de informação, especificamente pela variante conhecida como KPOT Stealer.

Src IP	SPort	Dst IP	DPort	Pr	Event Message
35.226.156.55	443	10.0.76.193	49207	6	ET POLICY Lets Encrypt Free SSL Cert Observed
10.0.76.109	49204	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Jun 13 2017
37.46.135.170	80	10.0.76.109	49204	6	ETPRO CURRENT_EVENTS RIG EK Landing Apr 04 2017 M5
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Suspicious Possible CollectGarbage in base64 1
37.46.135.170	80	10.0.76.109	49204	6	ET INFO Obfuscated fromCharCode
10.0.76.109	49203	37.46.135.170	80	6	ET CURRENT_EVENTS RIG EK URI Struct Mar 13 2017 M2
10.0.76.109	49203	37.46.135.170	80	6	ET POLICY Outdated Flash Version M1
37.46.135.170	80	10.0.76.109	49203	6	ETPRO CURRENT_EVENTS RIG EK Flash Exploit Sep 05 2017 (FWS)
10.0.76.109	49209	8.209.83.76	80	6	ET TROJAN Generic gate[.].php GET with minimal headers
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no referer
10.0.76.109	49211	8.209.83.76	80	6	ETPRO TROJAN KPOT Stealer Exfiltration M2
10.0.76.109	49211	8.209.83.76	80	6	ET TROJAN Trojan Generic - POST To gate.php with no accept headers
74.125.138.1...	80	10.0.76.193	49216	6	GPL WEB_CLIENT web bug 0x0 gif attempt
35.226.156.55	80	10.0.76.193	49261	6	GPL WEB_CLIENT web bug 0x0 gif attempt

Figura 1 Alertas encontrado no tráfego

Figura 13 Alertas encontrados no tráfego fornecidos pelo formador

A identificação é confirmada pelo alerta de segurança específico:

- ETPRO TROJAN KPOT Stealer Exfiltration M2

Este alerta é gerado quando o malware inicia atividades de roubo de dados, sendo uma assinatura confiável para identificação positiva do KPOT Stealer.

Método de Operação:

- Estabelece comunicação com servidores de Comando e Controlo (C2).
- Utiliza técnicas de exfiltração discretas para evitar deteção.
- Armazena dados temporariamente antes do envio.
- Utiliza endpoints específicos como gate.php para comunicação.

Exercício 6: IP do host que infetou a máquina

Como mencionado anteriormente o IP do host que infetou a máquina é 37.46.135.170 visto nos alertas de tráfego.

Pode-se também considerar o IP 8.209.83.76 como host que ajudou na infeção da máquina.

Exercício 7: Domínio do host que infetou a máquina

Para encontrar os vários domínios disponíveis vou usar o filtro “dns.qry.name”, ao observar a coluna “Info” vou procurar domínios suspeitos.

Não acabei por encontrar o domínio do 37.46.135.170, mas encontrei um domínio suspeito fghjkmgru34.site que é o domínio do IP 8.209.83.76, o host que recebe os dados roubados e ajudou na infeção do sistema.

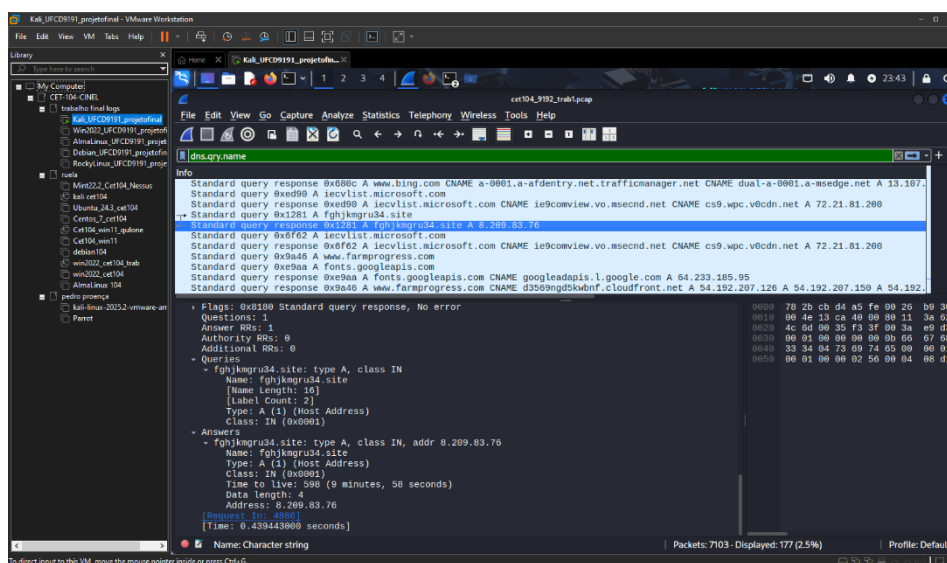


Figura 14 Domínio do host que infetou a máquina

Bibliografia

Fontes de informação usadas:

- Gravações das aulas,
- Apontamentos / Reptos efetuados,

Este trabalho tem também bastante inspiração dos meus dois trabalhos finais anteriores de Linux pois são parecidos em estrutura.

Conclusão

Este trabalho permitiu-me alcançar os objetivos propostos, obtendo conhecimentos práticos e teóricos em análise forense e investigação de incidentes de segurança.

A análise do ficheiro PCAP foi essencial para perceber todo o ataque, desde o momento em que o computador foi infetado até às comunicações que fez com os servidores dos hackers. A extração segura da SHA256 do executável forneceu um indicador de comprometimento crítico para futuras deteções.

Quanto aos métodos utilizados, destaca-se:

Wireshark: Ferramenta indispensável para análise detalhada de tráfego de rede, permitindo filtrar e seguir fluxos de comunicação específicos.

Análise Estática: Abordagem segura para extrair metadados e indicadores de ficheiros maliciosos sem risco de execução acidental.

Metodologia Forense: Processo estruturado para coletar, analisar e documentar evidências de forma reproduzível.

Resumindo, os resultados confirmam que a análise de tráfego de rede é uma componente essencial da segurança informática, permitindo não só detetar atividades maliciosas em tempo real, mas também investigar incidentes de segurança de forma retrospectiva.